DOCUMENTO INSTITUCIONAL

Plan de seguridad digital

IES Manuel de Falla
Móstoles · Comunidad de Madrid · Código 28028568
Avda. Olímpica, 16 — 28935 Móstoles (Madrid) · Coordinación TIC: Diego Navarro

5 prioridades · Cuentas protegidas · Copias que se restauran · Sesiones bloqueadas · Datos con acceso mínimo · Respuesta preparada

Hoja de ruta · Mes 1: Base y mayor riesgo → Meses 2–3: Control de datos → Meses 4–6: Ampliación y endurecimiento

Contacto · DPD: protecciondatos.educacion@madrid.org (91 720 4068) · INCIBE 017 · 112 Emergencias · TIC: 91 617 10 74

Este plan reúne las medidas mínimas para proteger las cuentas, los datos del alumnado y la continuidad de la actividad del instituto. Está pensado para aplicarse por fases, con pilotos y sin depender de herramientas que el centro no tiene.

Versión corregida UTF-8 — Tildes y “ñ” restauradas. Si ves “Móstoles”, “código”, “público” o “Olímpica” correctamente, el PDF ya está bien.

Aprobación: Dirección · DPD Consejería · Claustro · Consejo Escolar — Curso 2025/26

Contenido

1	Resumen — 5 prioridades y hoja de ruta a 6 meses	3
2	Finalidad, alcance y marco normativo (RGPD, LOPDGDD, ENS RD 311/2022)	4
3	Situación tecnológica y mapa de 9 riesgos	6
4	Identidades, sesiones y puestos — Bloqueo, MFA y cuentas privilegiadas	9
5	Datos, accesos y recuperación — Copias, clasificación y brechas	11
6	Red, dispositivos, correo y personas — Segmentación, SPF/DKIM/DMARC, MDM/EDR, FIDO2	13
7	Incidentes y continuidad — Procedimiento GRAV-72h y ficha Anexo B	15
8	Plan de acción — 22 medidas con prioridad, responsable y plazo	16
9	Glosario, fuentes y aprobación	18
Anexo A	Agenda de contactos (INCIBE 017, 112, DPD, TIC)	18
Anexo B	Ficha de incidente — plantilla en blanco	18
Anexo C	Inventario TIC — plantilla en blanco	19
Anexo D	Costes estimados (NAS, discos, llaves FIDO2)	19

Todas las entradas son enlaces en la versión digital. Pulsa para ir al apartado.

1 Resumen

Este plan reúne las medidas mínimas para proteger las cuentas, los datos del alumnado y la continuidad de la actividad del instituto. Está pensado para aplicarse por fases, con pilotos y sin depender de herramientas que el centro no tiene.

Cinco prioridades

01 **Cuentas protegidas** — MFA en dirección y administración, bajas revisadas y cuentas nominales, no compartidas.

02 **Copias que se restauran** — Una copia verificada y una prueba de restauración cada trimestre. No hay copia sin prueba.

03 **Sesiones bloqueadas** — Bloqueo automático en aulas y despachos, empezando por un piloto. Win+L / ⌘+Ctrl+Q.

04 **Datos con acceso mínimo** — Carpetas por función, proveedores revisados y política de IA generativa.

05 **Respuesta preparada** — Procedimiento, contactos y ficha de incidente impresos y a mano. Lo ensayado se hace bien.

Hoja de ruta a seis meses

Mes 1 — Base y mayor riesgo: confirmar plataformas y administradores, inventario y revisión de cuentas privilegiadas, primera copia verificada, MFA en administración y dirección, piloto de bloqueo automático, formación de inicio de curso.

Meses 2 y 3 — Control de datos: permisos y carpetas por función, primera restauración completa, mapa de datos y proveedores, política de IA generativa, diseño de la segmentación de red.

Meses 4 a 6 — Ampliación: simulacro de phishing, bloqueo en todas las aulas, segmentación de red, SPF/DKIM/DMARC, MDM/EDR en equipos compatibles, llaves FIDO2 en cuentas críticas, ejercicio de incidente.

2 Finalidad, alcance y marco normativo

1 — Finalidad

Este plan establece medidas para proteger la información del instituto, reducir los accesos indebidos y mantener la actividad educativa ante una pérdida, una cuenta comprometida, malware o ransomware. La actividad del centro depende de cuentas digitales, correo, plataformas educativas, equipos de aula, red y documentos compartidos: la protección debe impedir accesos accidentales, limitar el alcance de un fallo y permitir la

recuperación.

2 — Alcance

El plan cubre los datos de alumnado, familias y personal; calificaciones, exámenes, actas e informes de orientación; el correo y las cuentas administrativas; y los equipos de aula, portátiles y dispositivos conectados. Afecta a todo el personal del centro y a los servicios descritos en el apartado siguiente.

3 — Marco normativo y documentos de referencia

RGPD y LOPDGDD — Reglamento (UE) 2016/679 y Ley Orgánica 3/2018. Principios de tratamiento, seguridad de los datos personales y notificación de brechas.

Esquema Nacional de Seguridad (ENS) — Real Decreto 311/2022. Se aplica a todo el sector público (art. 2) y EducaMadrid indica que lo sigue. La Consejería, con el DPD, confirma qué sistemas del centro entran en su alcance.

Guía para centros educativos (AEPD) — El RGPD no fija un catálogo de medidas: se eligen según el riesgo de cada tratamiento. La guía figura como “en revisión”; conviene comprobar la versión vigente.

DPD de la Consejería de Educación: protecciondatos.educacion@madrid.org — 91 720 4068. Consultas y brechas de datos personales.

INCIBE, CISA y EducaMadrid: buenas prácticas para centros — bloqueo de sesión, MFA, copias aisladas y probadas, plan de respuesta a incidentes y formación. EducaMadrid publica principios de confidencialidad, integridad y disponibilidad.

3 Situación tecnológica y riesgos

Plataformas del centro: Google Workspace, EducaMadrid (usuario@educa.madrid.org), Alexia/Raíces, y equipos de aula con Windows/macOS. Red con segmentación pendiente; correo con SPF/DKIM/DMARC por completar; MDM/EDR en despliegue.

Mapa de 9 riesgos — valoración orientativa (probabilidad × impacto)

#	Riesgo	Prob.	Impacto	Descripción
1	**Sesión abierta**	Alta	Alto	Ordenador del aula sin bloquear. Cualquiera se sienta y lee notas, correo, exámenes.
2	**Contraseña robada (phishing)**	Alta	Alto	Correo que imita a EducaMadrid o al banco. Un clic y tu cuenta ya no es tuya.
3	**Ransomware (cifrado y chantaje)**	Media	Crítico	Cifra todo el disco y pide rescate. Sin copia aislada, no hay vuelta atrás.
4	**Cuenta sin baja**	Media	Alto	Profe o alumno que se fue pero su cuenta sigue activa con acceso a Drive.
5	**Acceso excesivo**	Media	Alto	Carpeta de Orientación compartida con todo el claustro. Datos sensibles expuestos.
6	**Datos en IA no autorizada**	Alta	Medio	Pegar notas con nombres en ChatGPT gratis. Ya no controlas dónde están.
7	**Red plana**	Baja	Alto	Invitados y alumnos en la misma red que Administración. Un salto y entran.
8	**Pérdida o robo**	Media	Medio	Portátil o pen perdido sin cifrar. Quien lo encuentra lo lee todo.
9	**Caída de EducaMadrid**	Media	Medio	Sin internet o plataforma caída en plena evaluación. Plan B offline necesario.

Valoración orientativa del Plan — debe validarse con DPD y Dirección. Medidas asociadas en el apartado 8.

Criterios de implantación: priorizar mayor riesgo (sesión abierta, phishing), aprovechar lo ya disponible (EducaMadrid, Windows Hello), pilotos antes de despliegue total y formación breve de inicio de curso.

4 Identidades, sesiones y puestos

Bloqueo automático: 5 min en aulas, 2 min en administración; piloto mes 1, despliegue total meses 4–5. Atajo: **Win+L** / **⌘+Ctrl+Q** siempre. Desactivar “mantener sesión iniciada” y “recordar contraseña” en equipos compartidos.

Cuentas y MFA: nominales, sin genéricas; revisión trimestral de altas/bajas; MFA obligatorio en dirección/administración (TOTP o llave FIDO2). educamadrid.org: usuario nominal, sin compartir; Google Workspace: alias solo si aporta valor.

Privilegios: mínimo necesario, revisión trimestral, doble administrador para cambios críticos, registro de actividad de Drive. Puestos compartidos: perfil invitado sin persistencia, borrado al cerrar sesión.

5 Datos, accesos y recuperación

Clasificación: público / interno / confidencial (notas, orientación) / restringido (salud, medidas judiciales). Carpetas por función, no por persona; Orientación solo para orientadores y tutores implicados.

Revisión de accesos: trimestral; al mover de grupo, revocar. Proveedores: contrato encargado, ubicación UE y medidas. No pegar datos con nombres en IA generativa no autorizada (ver apartado 6).

Copias y brechas: 3-2-1 (3 copias, 2 soportes, 1 externa); prueba de restauración trimestral; copia aislada (air-gap o inmutable). Brecha RGPD: notificar a AEPD en 72 h vía DPD si hay riesgo; comunicar a afectados si riesgo alto. Ficha Anexo B.

6 Red, dispositivos, correo y personas

Red: segmentación en 4 VLAN — alumnos / profesorado / administración / invitados; invitados con portal cautivo y sin acceso a recursos internos; IoT aislado. Diseño mes 3, implantación meses 4–6 con Ayuntamiento/Consejería.

Dispositivos: inventario Anexo C, MDM para portátiles del centro (borrado remoto, cifrado BitLocker/FileVault), EDR donde sea viable. Móviles: perfil de trabajo separado; BYOD solo con MDM o contenedor.

Correo: SPF (v=spf1), DKIM y DMARC (p=quarantine → p=reject) para evitar suplantación del dominio del instituto; revisión de reenvíos y delegaciones; formación anti-phishing y simulacro mes 4.

IA generativa: solo herramientas aprobadas con contrato; no alimentar con datos de alumnado; informar a familias; evaluar sesgos. Formación: 45 min inicio de curso + píldoras trimestrales + ejercicio de mesa.

7 Incidentes y continuidad

Procedimiento 6 fases — DETECTAR, CONTENER, ERRADICAR, RECUPERAR, COMUNICAR, APRENDER. No apagar si hay ransomware cifrando (aislar red y fotografiar nota de rescate). Preservar logs y capturas con fecha/hora.

Baja: Equipo aislado, sin datos personales.

Media: Varias cuentas o aula, posible dato sensible.

Alta: Ransomware, brecha o suplantación general.

Crítica: Datos masivos, chantaje, riesgo para persona.

Señuelos (honeytoken): “Presupuesto_Proyecto_2026.xlsx” sin datos reales en carpeta trampa; avisa a TIC si se abre. No usar datos reales ni credenciales. Continuidad: plan B offline (lista de contactos fuera de la red, copias locales) para caída de EducaMadrid o sin internet.

8 Plan de acción — 22 medidas

Veintidós medidas con prioridad, responsable y plazo. El detalle completo figura a continuación; la ficha y el inventario están en los Anexos B y C.

#	Medida	Responsable	Plazo	Prioridad
1	Inventario real de activos	TIC	Mes 1	**Alta**
2	Revisión de cuentas privilegiadas	TIC + Dirección	Mes 1	**Alta**
3	MFA en Dirección y Secretaría	TIC	Mes 1	**Alta**
4	Copia verificada + prueba de restauración	TIC	Mes 1 / Trimestral	**Alta**
5	Piloto bloqueo automático en aulas	TIC	Mes 1	**Alta**
6	Formación inicio de curso (phishing, bloqueo)	TIC + Orientación	Mes 2	Media
7	Carpetas por función (mínimo acceso)	TIC + Jefatura	Mes 2–3	**Alta**

#	Medida	Responsable	Plazo	Prioridad
8	Mapa de datos y proveedores	DPD	Mes 2–3	Media
9	Política de IA generativa del centro	Dirección + DPD	Mes 3	Media
10	Diseño de segmentación de red	TIC + Ayuntamiento	Mes 3	Media
11	Simulacro de phishing docente	TIC	Mes 4	Media
12	Bloqueo automático en todas las aulas	TIC	Mes 4–5	**Alta**
13	SPF, DKIM y DMARC en correo	TIC / Admin Workspace	Mes 5	Media
14	MDM/EDR en equipos compatibles	TIC	Mes 5–6	Media
15	Llaves FIDO2 en cuentas críticas	TIC	Mes 6	Media
16	Señuelos (honeytoken) en ficheros críticos	TIC	Mes 4	Media
17	Revisión trimestral de accesos	Jefatura + TIC	Trimestral	**Alta**
18	Ejercicio de mesa de incidente	DPD + TIC	Mes 6	Media
19	Actualización del inventario	TIC	Trimestral	Media
20	Auditoría de logs de Drive	TIC	Mensual	Media
21	Comunicación a familias del plan	Dirección	Mes 2	Media
22	Aprobación y firma del plan	Dirección / Consejo	Mes 1	**Alta**

9 Glosario, fuentes y aprobación

MFA: Doble factor: contraseña + app/SMS/llave FIDO2. Si te roban la contraseña, no entran.

EDR: Antivirus avanzado que vigila cada equipo y avisa al TIC si ve algo raro.

MDM: Gestión remota: instalar, bloquear o borrar un portátil/móvil perdido.

Phishing: Correo/SMS falso que imita ser tu banco o el instituto para robarte la clave.

Ransomware: Malware que cifra tus archivos y pide dinero para devolverlos.

DLP: Reglas que impiden sacar datos sensibles (p. ej., notas) fuera del centro.

DPD: Delegado de Protección de Datos de la Consejería: protecciondatos.educacion@madrid.org

SPF/DKIM/DMARC: Filtros que evitan que suplanten el correo del instituto.

FIDO2: Llave física de seguridad (p. ej., YubiKey) para MFA resistente al phishing.

Honeytoken: Señuelo — archivo falso que dispara alerta si alguien lo abre.

Fuentes: RGPD, LOPDGDD, ENS RD 311/2022, guías AEPD para centros, INCIBE, CISA (K-12 Toolkit, cyber decoys), EducaMadrid. Consultar siempre versión vigente.

Agradecimientos: al claustro y al personal de administración por la información aportada. Firmas: Dirección, Secretaría, Coordinación TIC, DPD.

Anexos

Anexo A — Agenda de contactos

INCIBE 017 — 900 116 117 — ayuda@incibe.es — 8:00–23:00, gratis y confidencial
112 Emergencias — si hay peligro o amenaza para persona
AEPD — dpd en 72 h vía DPD: 91 720 4068 / protecciondatos.educacion@madrid.org
TIC Diego Navarro — 91 617 10 74 — 91 236 94 06 — ies.manueldefalla.mostoles@educa.madrid.org
Ayuntamiento / Consejería — contacto red segmentada

Anexo B — Ficha de incidente

Plantilla en blanco para imprimir, con fecha/hora, informante, sistema, descripción, datos personales (RGPD), gravedad, acciones y firmas. Descargable en: /public/pdfs/plantilla-ficha-incidente.pdf

Anexo C — Inventario TIC

Elemento · tipo · ubicación · responsable · sistema/versión · gestión (GPO/MDM/EDR) · notas/n.º serie/IP. Plantilla en: /public/pdfs/plantilla-inventario.pdf

Anexo D — Costes estimados

Concepto	Precio	Fuente	Notas
NAS Synology DS425+	554,99 €	bechtle.com	Para copia local inmutable
Discos NAS 4×4 TB	~480 €	Por confirmar	Presupuestar aparte
Llaves FIDO2 (×10)	~50 €/ud	Fabricante	Para cuentas críticas
MDM/EDR licencias	Según nº equipos	Por confirmar	Cuota anual

Costes orientativos — confirmar con diagnóstico del mes 1 y presupuesto oficial.

Documento corregido UTF-8 — Todas las tildes (á, é, í, ó, ú, ñ) y diéresis visualizadas correctamente. IES Manuel de Falla — Móstoles, 2026.